MAJO BRIDGE TECHNOLOGIES AND EVENTS PLC

MaJo e-School Bridge (MayaBela) · INSA asset registration attachment

Security Documentation (posture, controls, risks, maturity)

Security Documentation

Product: MaJo e-School Bridge (MayaBela)
Insight into security posture and controls · validation of risks, controls, and maturity

Document number	MB-SEC-001
Version	1.0 · 10 November 2026 · East Africa Time (Africa/Nairobi)
INSA portal field	Security Documentation — provides insight into system security posture and controls; used to validate risks, controls, and security maturity.
Owner	Cyber Security Officer, Majo Bridge Technologies and Events PLC (Managing Director holds CSO duties until a dedicated hire is recorded).
Classification	CONFIDENTIAL — describes controls over children's records. Do not publish keys, PINs, or JWT contents.
Related records	CSMS pack; Guideline evaluation R3 (INSA-CSMS-AUD-MB-2026-11-09-R3); CMCSRS v2.0 evaluation; MB-SRS-001, MB-SDD-001, MB-TDD-001, MB-UG-001

This paper is a **summary of evidence already on file**. It is not a gazetted INSA certificate, not a third-party pentest letter, and not proof that live hosted project `hwkiihonthueadbhcvfi` already equals every hardened migration. Live SQL is applied only in a notified window so classrooms stay up.

1. Security posture (two evaluations, two answers)

INSA reviewers must not mix the two documents. The product CSMS was scored under the *Cyber Security Audit and Evaluation Guideline* v1.0 (May 2015 E.C., 40 pages). The operator was then checked against *CMCSRS version 2.0* (97 pages). Different pass rules; different result.

Product CSMS — Guideline v1.0

PASS · Mature 86/100 (Table 1: 76–90). Zero Major NCs on the submitted TOE. People / process / technology CSMS adopted. Remaining items (external pentest, CC laboratory certificate, live apply window) are Minor / observations.

Operator — CMCSRS v2.0

FAIL — NOT CONFORMANT. Must-clause gaps: locally licensed cloud (6.29.k), organisation-held cloud keys (6.29.f), foreign outsourcing (6.2.e / 6.38.i), INSA accreditation (6.22/6.23), annual compliance letter (6.24), DSAP national files (6.37). Finding IDs MNC-V2-01 to MNC-V2-06.

CIA objectives the product is built to meet: School A cannot read School B; a role sees only what that role needs; drivers see only their bus; privileged desks (Admin, Finance) use a second factor; classroom teachers are not locked out of lessons.

2. Control catalogue

Controls are people, process, and technology (INSA Guideline CSMS model). Implementation detail is MB-TDD-001; architecture is MB-SDD-001.

ID	Control	Layer	How it is evidenced
C-01	Information security policy, named CSO, RACI	People	CSMS-POL-001, CSMS-RACI-001
C-02	Acceptable use; no student-row dumps; no service-role in chat	People	CSMS-HR-001; school-admin go-live acknowledgement
C-03	Living risk register; treatment + residual + owner	Process	CSMS-RISK-001 (this paper §3)
C-04	Incident response including Ethio-CER2T steps	Process	CSMS-IRP-001; 24/7 +251 911 646 444
C-05	Continuity: local restore drill; hosted RPO is the supplier's	Process	CSMS-BCM-001 + records/
C-06	Internal audit programme + CAAT on CI	Process	CSMS-AUD-001, CSMS-TEV-001
C-07	JWT school_id and role from `app_metadata` only	Technology	MB-TDD-001; CAAT 12 (two-school)
C-08	RLS on `app_documents`; teacher module gates; driver need-to-know	Technology	CAAT 10 (hardening), 11 (driver 9/9), 12 (7/7)
C-09	Privileged MFA: School Admin + Finance. Teachers opt-in	Technology	`isPrivilegedMfaRole`; Flutter tests
C-10	Login: bcrypt, 10+ password, 8 tries / 15 min. PIN: PBKDF2 210000	Technology	CSMS-KEY-001; Deno PIN tests
C-11	Service-role key forbidden in the client; Edge functions catalogued (25) with an auth mode	Technology	`edge_auth_inventory.ts`; `guardRegistryRecord`
C-12	Public bucket = logos only; student files under `schools/<id>/`	Technology	MB-SDD-001 TB-5; MB-UG-001 UR-08
C-13	Maya Assistant: counts only; refuses health/safeguarding/IDs; SIS runs if AI key unset	Technology	CSMS-DPIA-001
C-14	Web headers: HSTS, CSP, frame deny; HTTPS only	Technology	`web/_headers`
C-15	Production is never the RLS isolation target; staging then notified window	Process	`tools/test_rls_isolation.mjs`; CSMS-POL-001 §2.5
C-16	Supplier / residency register; dedicated or on-prem path for schools that cannot share foreign hosting	Process	CSMS-SUP-001, CSMS-DPA-001

3. Risks and how they are treated

Source: CSMS-RISK-001. Likelihood × impact 1–5. Residual is after the 9 November 2026 source controls. Live apply of those controls remains a notified window (R9).

Risk	L×I	Treatment	Control	Residual
R1 Cross-school leak	2×5	Mitigate: JWT school + RLS; two-school CAAT	C-07, C-08	Medium until live negative test is green
R2 Teacher writes payroll/HR	2×4	Mitigate: module gates in source	C-08	Low in candidate
R3 Driver reads all students	3×4	Mitigate: own-bus only	C-08	Low in candidate
R4 Fee marked paid without cashier	2×4	Mitigate: paid-status is finance	C-08, C-09	Low in candidate
R5 Admin password in school_registry	2×5	Mitigate: strip trigger	C-08	Low in candidate
R6 Service-role Edge bypass	3×4	Mitigate: inventory + registry guard	C-11	Medium — other functions inventoried
R7 Cloud region / sovereignty	3×4	Transfer/avoid: on-prem path; INSA exception or local CSP still open	C-16	Medium (CMCSRS Must residual)
R8 Maya Assistant PII	2×4	Mitigate: counts-only context	C-13	Low
R9 Production lagging source	3×4	Accept until notified window — do not rush live schools	C-15	Accepted
R10 No external pentest yet	3×3	Mitigate later: CAAT now; pentest after staging apply	C-06	Medium
R11 Lost laptop with school JWT	2×3	Mitigate: short JWT; MFA on privileged desks; password change revokes	C-09, C-10	Medium (shared teacher PCs)
R12 On-prem power/IP outage	4×3	Accept (customer power); BCM file	C-05	Accepted
R13 Finance MFA lockout	2×3	Mitigate: prompt enroll, login still works; teachers stay opt-in	C-09	Low

User-related risks that technical controls cannot fully close (screenshot of a class list, password on WhatsApp, student photo uploaded as logo) are in MB-UG-001 UR-01–UR-14.

4. Security maturity — how it was scored

4.1 Guideline v1.0 (product + CSMS)

Guideline §8.5.e: significance of issues determines pass or fail. §9 Table 1: 76–90 = Mature (“improvements required to key security areas identified with weaknesses”). Evaluation R3 (9 November 2026) closed Major NCs on the submitted TOE (CSMS pack, driver need-to-know, finance MFA without locking teachers, two-school CAAT, Edge inventory, restore drill, CC-inspired Security Target). Score path: FAIL 38 → R2 Developing 64 → **R3 Mature 86**.

Maturity area	Band on submitted TOE	Weakness still open (Minor / observation)
People	Operating (policy, CSO, awareness record)	National clearance files / DSAP scheme not in git

Maturity area	Band on submitted TOE	Weakness still open (Minor / observation)
Process	Operating (risk, IRP, BCM, internal eval)	No INSA accreditation path yet; no annual Minister/INSA letter
Technology	Operating on candidate (JWT/RLS/CAAT)	External pentest letter; live SQL may lag source; hosted disk keys not MaJo-held

4.2 CMCSRS v2.0 (operator)

Must clauses are pass/fail. Exceptional skips need INSA approval. MaJo is treated as a key private organisation processing CONFIDENTIAL children's data. IoT, blockchain, and ICS are N/A with justification (CSMS-CMCSRS-001). Remaining Must gaps cannot be closed in Flutter: they need a locally licensed CSP or INSA exception, customer-managed keys or on-prem, accreditation, an annual letter, and DSAP files. **86/100 is not reprinted as a CMCSRS score.**

5. What this documentation does not claim

- A gazetted INSA certificate, gateway certificate, or Common Criteria laboratory (CB) certificate.
- An independent web/API pentest letter (scheduled after staging apply — R10 / TV-09).
- That the live hosted database already contains every INSA migration in source (R9 / TV-07).
- Organisation custody of hosted disk encryption keys (MNC-V2-02 / TV-06).
- That classroom teachers are forced onto MFA (explicitly not done).
- That login logos were hidden (public branding is required so the login page can show a stamp without a JWT).

6. How a reviewer validates this pack

1. Policy and RACI: CSMS-POL-001, CSMS-RACI-001.
2. Risks: this §3 and CSMS-RISK-001.
3. Technical controls: MB-TDD-001 plus CAAT `10_insa_permission_hardening.sql`, `11_insa_driver_need_to_know.sql`, `12_insa_two_school_isolation.sql`.
4. Maturity number: Guideline R3 PDF — `INSA_CSMS_Audit_Evaluation_Report_MayaBela.pdf`.
5. Operator residuals: CMCSRS v2.0 PDF — `INSA_CMCSRS_v2_Audit_Evaluation_Report_MayaBela.pdf`.
6. Misuse: MB-UG-001. Architecture: MB-SDD-001. Requirements: MB-SRS-001.

Prepared by (CSO)	For INSA asset registration
Majo Bridge Technologies and Events PLC · 10 November 2026, East Africa Time	Attachment to field: Security Documentation